인터넷 사업 101

사이트를 만들고, 고치고, 지키고, 키우는 법 — 입문부터 실전까지

이 덱의 흐름 : 5 단계

1

큰 그림

사업 종류 · 수익 모델 · 용어

1–3 장

2

만들기

기획 · 사이트 구조

4–5 장

3

운영하기

환경 · 배포 · 백업 · 장애 · 법

6–10 장

4

키우기

마케팅 · 데이터 · B2B/B2C

11–12 장

5

실전

시뮬레이션 · 체크리스트

13–15 장

가운데 '운영하기'가 이 공부의 중심입니다

누가 누구에게 파는가 : B · C · G

B 기업 Business

C 개인 Consumer

G 정부 Government

B2C	기업 → 개인	**B2B**	기업 → 기업
쇼핑몰 , 넷플릭스		슬랙 , 회계 프로그램	
C2C	개인 → 개인	**B2B2C**	기업 → 기업 → 개인
당근마켓		배달앱	
D2C	제조사 → 개인 직접	**B2G**	기업 → 정부
브랜드 자사몰		공공 입찰	

B2C 는 ' 많이 · 싸게 · 빨리 ', B2B 는 ' 적게 · 비싸게 · 꼼꼼히 '

직접 파나, 장터를 깔아 주나

직접 판매 (자사몰)

내 물건을 내가 판다

- 돈: 판매가 - 원가
- 부담: 재고, 배송, 반품
- 예: 브랜드 자사몰

플랫폼 (마켓플레이스)

남의 물건이 팔리는 장터

- 돈: 거래액의 몇 % 수수료
- 숙제: 판매자와 손님을 동시에 모으기
- 예: 에어비앤비, 크몽

돈 버는 방법 4 대장

1

판매

물건을 팔고 차익

쇼핑몰

2

구독

매달 정기 결제

넷플릭스 , SaaS

3

수수료

거래마다 몇 %

배달앱 , 에어비앤비

4

광고

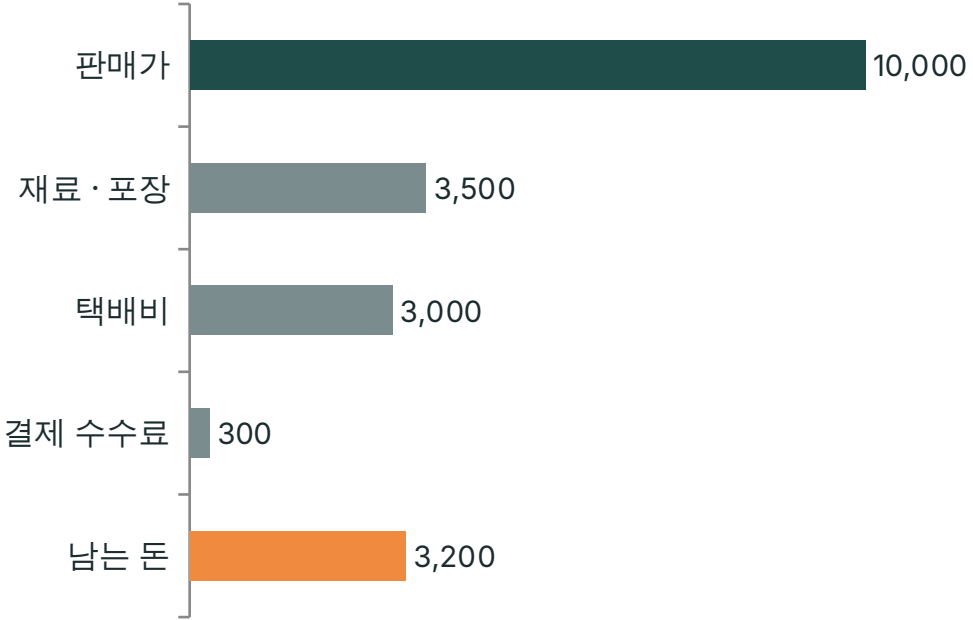
방문자에게 광고 노출

블로그 , 유튜브

그 밖에 프리미엄 (기본 무료) · 사용량 과금 · 리드 판매 · 제휴 마케팅

매출보다 '1개 팔 때 남는 돈'

1만 원짜리 간식 1개



광고로 손님 1명 데려오는 데

5,000 원

이 들면, 첫 구매만으로는 1,800원 손해

→ **재구매와 객단가 올리기가 중요**

먼저 외울 용어 12 개

MVP
핵심만 넣은 첫 버전

KPI
잘하고 있나 판단하는 숫자

전환율
방문자 중 구매 비율

객단가
주문 1 건 평균 금액

CAC
손님 1 명 데려오는 비용

LTV
손님 1 명이 평생 내는 돈

Churn
구독 해지 비율

MRR
매달 반복 매출

ROAS
광고비 1 원당 매출

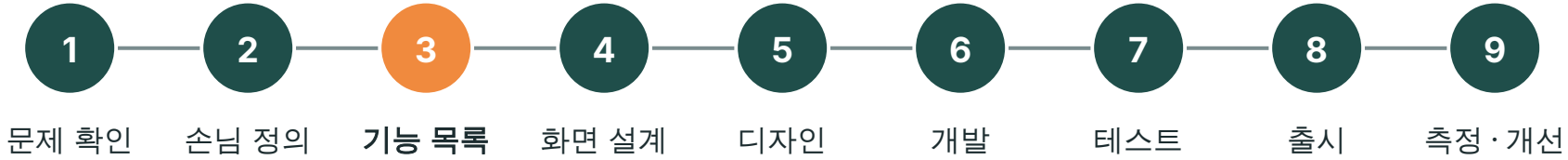
SEO
검색에 잘 뜨게 하기

배포
고친 걸 실제 사이트에 반영

롤백
이전 버전으로 되돌리기

전체 목록은 docs/03-glossary.md

기획에서 출시까지 , 그리고 반복



⑨ 측정 결과를 보고 ③ 기능 목록으로 돌아가 다시 고친다

첫 출시는 Must 기능만 (MVP)

쇼핑몰이면 : 상품 보기 · 장바구니 · 결제 · 주문 확인

사이트는 세 덩어리 , 지키는 방법도 셋

1 코드

화면 , 프로그램

내가 고칠 때만 바뀜

→ Git (버전 관리)

2 데이터 (DB)

회원 , 주문 , 결제

매초 바뀜

→ DB 자동 백업

3 파일

상품 사진 , 첨부

상품 올릴 때 바뀜

→ 저장소 백업

폴더를 통째로 복사해도 주문 · 회원 정보 (DB) 는 빠져 있는 경우가 많다

' 백업 폴더 만들어서 고치나요 ?' 에 대한 답

초보자 방식

```
myshop/
myshop_backup/
myshop_ 최종 /
myshop_ 최종 _ 진짜최종 /
myshop_ 최종 _ 진짜최종 _ 수정 2/
```

무엇이 바뀌었는지 모르고 , DB 는 빠져 있음

현업 방식

1. **환경을 나눈다**
   연습용 사이트 (스테이징) 에서 먼저 고친다
2. **Git 으로 기록한다**
   모든 변경을 저장 , 언제든 되돌린다
3. **DB 는 따로 백업한다**
   손님 데이터는 자동 백업으로 지킨다

환경 3 개 : 운영 사이트는 직접 고치지 않는다

로컬

연습장

나만 봄 . 마음껏 고치고 부수기

→

스테이징

리허설 무대

운영과 똑같이 . 최종 확인

→

운영

실제 무대

진짜 손님 . 직접 수정 금지

빌더 (카페 24· 아임웹) 라면 ? 기존 디자인 스킨을 복사 → 복사본에서 수정 → 확인 후 '대표 디자인으로 적용 ' = 같은 개념

Git 은 게임 세이브와 같다

1	**커밋**	세이브 포인트에 저장
2	**브랜치**	세이브를 복사해 다른 선택지 시험
3	**머지**	좋은 선택지를 본 세이브에 합치기
4	**되돌리기**	이전 세이브 포인트로 돌아가기
5	**GitHub**	세이브를 인터넷 금고에 보관

흔한 작업 순서

1. main 에서 브랜치 만들기
2. 브랜치에서 고치고 커밋
3. 스테이징에서 확인
4. main 에 머지 → 배포
5. 문제 시 이전 커밋으로

업데이트 (배포) 표준 절차

1. **기록** — 무엇을 왜
2. **백업** — DB + 현재 버전
3. **스테이징** — 핵심 흐름 확인
4. **시간 고르기** — 손님 적을 때
5. **배포**
6. **확인** — 10–30 분 감시
7. **기록** — 릴리스 노트

먼저 되돌리고 , 나중에 고친다

배포 후 문제가 생기면 원인부터 찾지 말고 롤백 . 금요일 저녁 · 이벤트 직전 배포는 피하기

손님 몰래 바꾸는 3 가지 기술

블루 - 그린

무대 두 개

새 버전을 옆에 띄우고 손님 입구만 바꿈

되돌리기 : 입구를 원래대로

카나리

조금씩 공개

손님 1% → 10% → 100% 순서로 보여 줌

되돌리기 : 비율을 0% 로

기능 플래그

전등 스위치

기능을 미리 배포해 두고 스위치로 켬

되돌리기 : 스위치 끄기

백업의 기본 공식 : 3-2-1

3

개의 복사본

원본 + 백업 2 개

2

가지 저장 장치

한 장치가 고장 나도 안전

1

개는 다른 장소

해킹 · 화재에도 살아남게

복구해 봐야 진짜 백업 . 분기마다 백업을 연습용 사이트에 되살려 보고 걸린 시간을 잰다

얼마나 잃어도 되나 : RPO 와 RTO

RPO

몇 시간 치 데이터를 잃어도 되나 ?

줄이려면 → 백업을 더 자주

RTO

몇 시간 안에 다시 살려야 하나 ?

줄이려면 → 복구 절차 문서화 · 연습

사이트	RPO 예	RTO 예
블로그	1 일	1 일
쇼핑몰	1 시간 이하	몇 시간
B2B SaaS	계약 (SLA) 대로	계약 (SLA) 대로

모니터링과 장애 대응

자동으로 지켜볼 것

- 사이트가 살아 있나 (1–5 분마다)
- 오류가 늘었나
- 느려졌나
- 서버가 힘든가
- 주문이 너무 적지 않나 ← 의외로 중요

장애가 나면 5 단계

1. 알아채기
2. 알리기 (공지)
3. **멈추기 (롤백)**
4. 고치기
5. 돌아보기 (포스트모템)

작은 사이트도 공격당한다 : 보안 기본 6 가지

1 2 단계 인증

비밀번호가 털려도 로그인 불가

2 최신 업데이트

알려진 구멍 막기

3 최소 권한

직원에겐 필요한 메뉴만

4 퇴사자 계정 삭제

의외로 사고가 많은 곳

5 카드번호 저장 안 하기

결제는 PG 사에 맡기기

6 다른 곳에 백업

랜섬웨어 대비

한국에서 쇼핑몰을 시작하는 순서

1
사업자등록
홈택스

2
통장 · 카드
사업용

3
PG + 에스크로
결제 대행

4
통신판매업 신고
정부 24· 구청

5
사이트 표시
사업자정보 · 약관 · 처리방침

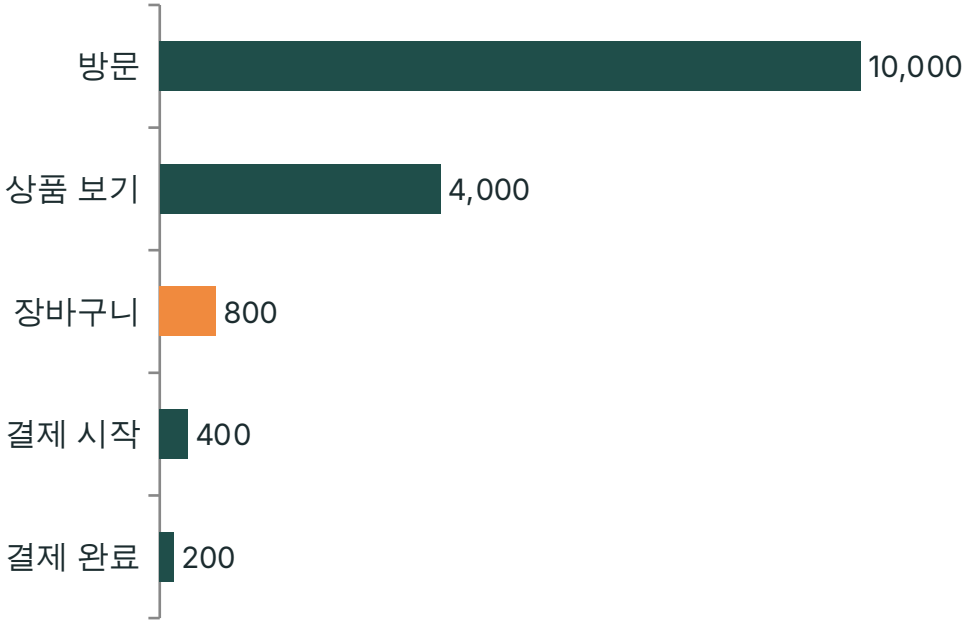
6
영업 · 세금
부가세 · 종소세

개인정보 5 원칙 최소 수집 · 동의 (마케팅은 따로) · 처리방침 공개 · 안전 보관 · 파기

법은 자주 바뀝니다 . 시작 전 홈택스 · 정부 24· 개인정보보호위원회에서 재확인

매출 = 방문자 × 전환율 × 객단가

퍼널 : 단계마다 손님이 줄어든다



전환율

2%

상품 보기 → 장바구니에서 가장 많이 빠진다 (4,000 → 800)

→ 가장 많이 빠지는 단계부터 고친다

B2C 와 B2B 는 운영이 다르다

	B2C (개인)	B2B (기업)
손님 수 · 금액	많고 작다	적고 크다
사기까지	몇 초 ~ 며칠	몇 주 ~ 몇 달
결정하는 사람	본인	여러 명 (팀장 · 구매 · 보안)
결제	카드 즉시	세금계산서 · 연간 계약
마케팅	SNS 광고 · 후기	영업 · 사례 · 세미나
운영 핵심	광고 효율 · 재구매 · CS 대량 처리	SLA · 온보딩 · 고객 성공

운영 리듬 : 언제 무엇을 점검하나

매일

- 주문 · 문의
- 모니터링 알림
- 어제 매출 · 광고비

매주

- 백업 성공 확인
- 데이터 내보내기
- 보안 업데이트

매월

- 도메인 · 카드 만료일
- 안 쓰는 계정 정리
- 월 손익

분기

- 복구 훈련
- 비밀번호 교체
- 약관 점검

전체 점검표는 docs/14-checklists.md

여러 가지 사이트 사업

커뮤니티 · 정보 사이트 · 트래픽 수익 · 로또 사이트 · 게임 (오목) · 아이템 비교 — 16–21 장

커뮤니티 : 회원이 콘텐츠를 만든다

1% 글을 열심히 쓴다

9% 가끔 댓글을 단다

90% 읽기만 한다

운영의 핵심

- 주제를 좁게 , 처음엔 운영자가 직접 글 쓰기
- 짧고 구체적인 규칙 + 처벌 수준 명시
- 모든 제재를 기록 , 관리자 권한은 최소한만
- 삭제 요청엔 삭제 또는 임시조치 (최대 30 일)
- 수익화는 회원 신뢰를 해치지 않게

정보 사이트 : 검색 → 답 → 광고 · 제휴



약해진 것

- 'OO 란 ?' 같은 단순 정의 글
- 검색에만 의존
- 글 대량으로 찍어내기 (스팸)

강해진 것

- 직접 해 본 후기 , 나만의 데이터
- 계산기 같은 도구
- 뉴스레터 · 커뮤니티 구독자

트래픽 수익 = 페이지뷰 ÷ 1,000 × RPM

10 만

월 페이지뷰

× 2,000 원

RPM (예시)

= 20 만 원

월 광고 수익

계정 정지되는 행동

내 광고 내가 클릭 · '광고 눌러 주세요' · 트래픽 구매 · 봇 · 금지 콘텐츠 · 위장 광고
제휴 링크엔 '수수료를 받는다'는 광고 표시 필수

RPM 은 주제 · 방문자에 따라 수십 배 차이 — 위 숫자는 계산 연습용 예시

로또 사이트 : 어디까지 괜찮나

괜찮음

- 당첨 번호 통계 · 그래프
- 무료 랜덤 생성기 (' 재미용 ' 표시)
- 당첨금 세금 계산기

주의

- ' 통계 추천 번호 ' 로 효과 과장
- 무료 번호 미끼로 전화번호 수집

위험 · 불법

- 유료 ' 당첨 번호 예측 ' · 보장
- 복권 구매 대행
- 로또 번호 사설 베팅

모든 번호 조합의 1 등 확률은 같다 : 8,145,060 분의 1. 돈 받고 당첨을 약속하면 선을 넘은 것

게임 사이트 : 오목으로 배우기

설계 핵심

- AI 대전부터 (사람이 적어도 돌아가게)
- 빠른 대전 매칭 + 레이팅 (실력 점수)
- 판정은 서버가 (조작 방지)
- 부정행위 (AI 따라 두기)· 탈주 대응
- 배포는 진행 중인 판이 끝난 뒤

게임법 3 가지

1 **등급분류**
앱 마켓은 자체 등급 , 내 사이트는 직접 확인

2 **환전 금지**
이기면 돈을 받는 구조 = 도박

3 **확률 공개**
유료 뽑기는 확률을 % 로 공개

사업 아이템 비교와 키우는 순서

아이템	시작	개발	운영 부담	위험
정보 블로그 · 뉴스레터	쉬움	거의 없음	중간	낮음
도구 (계산기) 사이트	쉬움	조금	낮음	낮음
커뮤니티	보통	조금	높음	중간
대전 게임 (오목)	어려움	많음	높음	중간
SaaS · 중개 플랫폼	매우 어려움	많음	매우 높음	높음

한 주제로 키우기

1. **정보 · 도구**
2. **커뮤니티**
3. **게임 · 상품**

앞 단계의 방문자가 다음 단계의 첫 손님

더 넓은 분류

분류 지도 · 셀러 · 크리에이터 · 앱 · 지식 · 외주 · 중개 플랫폼 · AI · 규제 업종 — 22–29 장

사업을 나누는 6 가지 기준

1 누구에게

B2C · B2B · C2C · B2G

2 무엇을

실물 · 디지털 · 서비스 · 소프트웨어 · 콘텐츠

3 어떻게 버나

판매 · 구독 · 수수료 · 광고 · 후원

4 누가 만드나

운영자 · 회원 · 판매자 · AI

5 어디서

내 사이트 / 남의 플랫폼

6 규제

신고만 / 등록·허가 / 금지

새 아이디어는 6 칸을 채워 보며 위험을 찾는다 (22 장)

오픈마켓 셀러와 크리에이터

오픈마켓 셀러 23 장

- 손님은 이미 있음 , 대신 수수료 · 경쟁
- 사입 · 위탁판매 · 구매대행 · 내 브랜드
- 마켓 안 검색 최적화 + 수수료 뺀 마진
- 배송 기한·CS 점수 관리

크리에이터 24 장

- 콘텐츠 = 제품 , 업로드 = 배포
- 광고 배분 + 후원 · 멤버십 + 협찬
- 협찬은 반드시 광고 표시
- 원본 백업 · 2 단계 인증 · 팬을 내 채널로

앱은 웹보다 업데이트가 어렵다

1 심사

올려도 마켓 심사를 통과해야 나감

2 되돌리기 불가

이미 깔린 버전은 되돌릴 수 없음

3 옛 버전 공존

업데이트 안 한 사람이 계속 남음

그래서 쓰는 장치

단계적 출시 · 베타 테스트 · 기능 플래그 · 서버에서 설정 바꾸기 · 강제 업데이트 · 크래시 리포트

디지털 상품 결제엔 앱 마켓 수수료 15–30% (조건에 따라)

지식 · 외주 판매와 중개 플랫폼

지식 · 외주 (26 장)

1. **디지털 상품**
   한 번 만들어 계속 판매

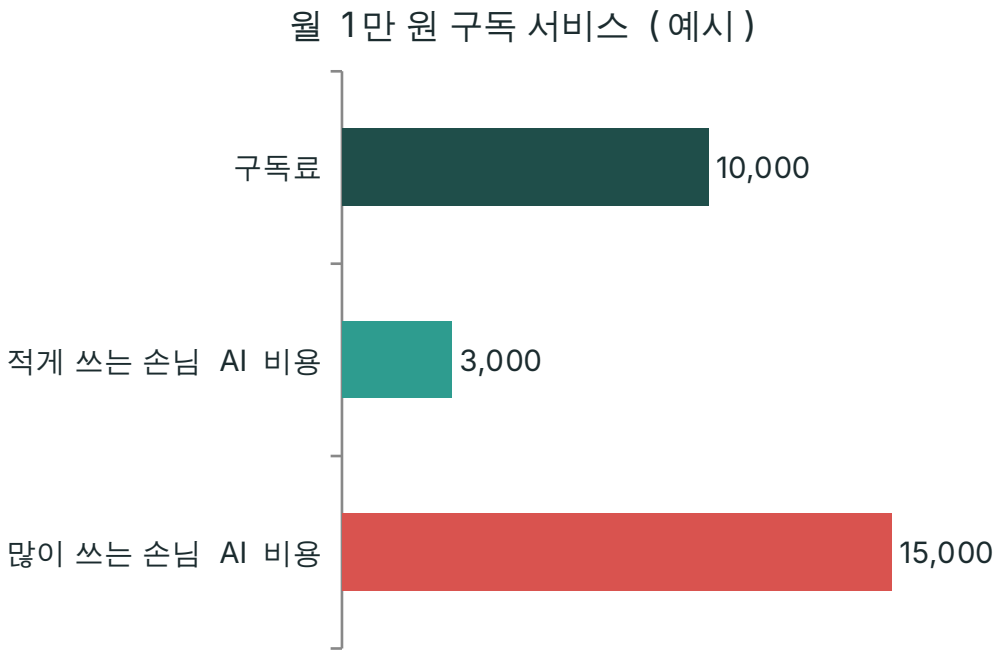
2. **강의 · 코칭**
   만들기 전 사전 신청으로 수요 확인

3. **외주**
   계약서 : 범위 · 수정 횟수 · 저작권

중개 플랫폼 (27 장)

- 한쪽 먼저 , 좁은 지역 · 분야부터
- 신뢰 장치 : 본인 확인 · 리뷰 · 안전결제
- 탈중개 (직거래) 막을 혜택 만들기
- 구인구직 · 결혼중개 · 숙박 · 의료는 업종별 신고 · 등록 확인

AI 서비스 : 쓸 때마다 원가가 나간다



운영 체크

- 사용량 제한 · 과금
- 틀린 답 (환각) 안내
- 모델 바뀌면 테스트
- 입력 정보 외부 전송 고지
- AI 생성물 표시 (AI 기본법)

시작 전에 확인할 규제 업종

신고 정도면 시작	일반 쇼핑몰 · 정보 사이트 · 템플릿
추가 신고 · 등록	건강기능식품 · 직업소개 · 위치정보 · 게임
허가 · 라이선스	결제 · 송금 · 투자자문 · 가상자산 · 의료
온라인 판매 금지 · 제한	의약품 · 담배 · 주류 (일부 예외) · 도수 렌즈

애매하면 정부 24 에서 업종 인허가 검색 , 관계 기관 · 전문가에게 확인 (29 장)

문의 · 광고 받기

문의 창구 · 도메인 이메일 · 스팸함 피하기 · 광고 메일 규칙 · 광고·제휴 문의 — 30–31 장

시작은 도메인 이메일 1개 + 문의 폼 1개

문의 창구

- 이메일 — 모든 사업의 기본
- 문의 폼 — 필요한 정보만, 스팸 막기 쉬움
- 1:1 게시판 · 카카오톡 채널 · 채팅
- 앱 안 문의 · 마켓 문의 기능
- 창구가 많을수록 놓치는 문의도 늘어남

용도별 주소 (한 메일함으로 모으기)

help@	일반 문의
ads@	광고·제휴
privacy@	개인정보 요청
report@	불법 게시물 신고
billing@	결제·환불

스팸함에 안 빠지게 : SPF · DKIM · DMARC

MX

우편함 위치

어느 서버가 메일을 받나

SPF

보내는 우체국 명단

내 이름으로 보내도 되는 서버

DKIM

봉투의 도장

중간에 안 바뀌었다는 서명

DMARC

처리 지침

검사 실패 메일을 어떻게 할지

설정 팁 값은 내 메일 서비스가 알려 주는 그대로 · SPF 는 도메인당 하나 (합치기) · DMARC 는 p=none 으로 시작해 단계적으로

대량 발송 규칙 하루 약 5,000 통 이상이면 세 가지 모두 + 원클릭 수신거부 + 스팸 신고율 0.3% 미만 (Gmail·Yahoo)

광고 메일 · 문자를 보낼 때 5 가지 규칙

1	사전 동의	약관에 섞지 말고 선택 항목으로 따로
2	(광고) 표시	제목 · 문자 맨 앞에
3	쉬운 수신거부	로그인 요구 등 방해 금지
4	야간 별도 동의	흔히 21 시 ~ 다음 날 8 시
5	2 년마다 확인	계속 받을지 다시 묻기

주문 안내 같은 거래 메일에 광고를 섞지 않기 — 정보통신망법 제 50 조 (30 장)

광고 · 제휴 문의 받기

준비물

- 광고 문의 페이지
- ads@ 전용 주소
- 미디어킷 : 방문자 숫자 · 독자 특징 · 상품 · 가격 · 원칙

진행 순서

1. 광고주 확인
2. 견적 · 계약
3. 선불 결제
4. 소재 검수
5. 광고 표시 게재
6. 결과 보고

거절할 광고

- 불법 도박 · 토토
- 성인물
- 수익 보장 투자 · 코인
- 의약품 효능
- 광고 표시 없이 해 달라는 요청
- 백링크 판매 · 수상한 첨부 파일

마케팅 실전

인스타그램 시작하기 · 광고 예산 · 네이버 · 당근 · 실제 사례 10 가지 · 90 일 계획 — 32–33 장

인스타그램 첫날 : 프로필부터

1. **프로페셔널 계정**
   통계 · 광고 · 연락처 버튼
2. **소개 글 3 줄**
   누구를 위한 / 무엇을 / 지금 할 행동
3. **링크 + UTM**
   인스타에서 온 손님을 따로 세기
4. **하이라이트**
   후기 · FAQ · 이벤트 · 배송

콘텐츠 3 종류

절반	**도움 되는 것** 저장 · 공유로 새 사람에게
1/3	**믿음 주는 것** 과정 · 후기 · 대표 이야기
조금	**사게 하는 것** 신제품 · 할인

판매 글만 있는 계정은 팔로우할 이유가 없다 (32 장)

인스타그램이 보는 3 가지 신호

시청 시간

끝까지 보나

인사이트 : 평균 시청 시간

좋아요

팔로워에게 퍼지는 힘

인사이트 : 도달 대비 좋아요

보내기

모르는 사람에게 퍼지는 힘

인사이트 : 도달 대비 보내기

영상 팁 첫 1~2 초에 결론 · 자막 필수 · 한 영상 한 메시지 · " 친구에게 보내 주세요 "

해시태그 2025 년 12 월부터 5 개 제한 보도 → 캡션 첫 줄과 영상 속 단어가 더 중요

기준 인스타그램 책임자 애덤 모세리 , 2025 년 1 월 발표 (보도 기준)

메타 광고 첫 예산 계산법 (업계 경험칙)

하루 예산 ≈ 목표 전환 1 건 비용 × 50 ÷ 7

예) 구매 1 건 1 만 원 목표 → 하루 약 7 만 원

- 약 7 일에 최적화 이벤트 50 회 = 학습 끝이라는 업계 안내
- 부담되면 목표를 앞 단계 (장바구니 · 상세 보기) 로
- 반응 좋았던 릴스를 광고 소재로
- 첫 1 주는 자주 건드리지 않기

광고 구조

캠페인 목표

광고 세트 누구에게 · 얼마 · 언제

광고 영상 · 이미지 · 문구

한국 동네 장사 : 네이버 · 당근 · 카카오

네이버 스마트플레이스

- 정보 · 사진 · 메뉴 최신으로
- 진짜 손님 리뷰를 꾸준히 + 사장님 답글
- 리뷰 · 저장 구매 (어뷰징) 금지

블로그 · 체험단

- 작은 세부 키워드부터 공략
- " 제품을 제공받아 작성 " 표시
- 키워드 전략은 내가 정하기

당근 · 카카오 채널

- 당근 비즈프로필 : 동네 소식 · 쿠폰
- 카카오 채널 : 재방문 쿠폰 · 예약 안내
- 광고 메시지는 수신 동의 규칙

실제 사례 : 처음에 무엇을 했나

사례	처음에 한 일	배울 점
배달의민족	길거리 전단지를 주워 가게 정보 입력	처음엔 손으로 직접
당근	판교 회사 사내 장터 → 동네 인증	좁게 시작
무신사	스니커즈 마니아 커뮤니티	팬이 먼저 , 상품은 나중
오늘의집	온라인 집들이 사진 + 구매 버튼	즐겨 보는 콘텐츠에 구매 연결
모닝 브루 · 드롭박스	공유 칸 / 친구 초대하면 용량	공유가 제품 안에
워들 · 어몽어스	이모지 공유 카드 / 스트리머 방송	사람 있는 곳으로
듀오링고	부엉이 마스코트를 캐릭터로	브랜드에 성격

90 일 실행 계획

1~4 주

씨앗 뿌리기

- 도움 되는 콘텐츠 주 3~5 개
- 첫 손님 30 명에게 직접 연락
- 후기 · 질문 전부 모으기

5~8 주

반응 찾기

- 상위 콘텐츠 3 개 찾기
- 같은 주제 변형 5 개 더
- 소액 광고 테스트 · 공유 장치

9~12 주

키우기

- 되는 채널에 집중
- 작은 크리에이터와 협업
- 이메일 · 카카오로 단골 만들기

매주 금요일 30 분 : 도달 · 링크 클릭 · 가입 · 구매 · 광고비 · 다음 주 실험 1 개

도메인 : 주소와 업계 지식

도메인 이름 (사이트 주소) 고르기 · 연결 · 지키기 · 업계 지식 (도메인 지식)
분야별 흐름 — 34–35 장

도메인 주소 읽기와 고르기

```
https://shop.granolalab.co.kr/products
```

서브도메인
shop — 마음대로 추가

도메인 이름
granolalab — 내가 빌린 이름

TLD
.co.kr — 종류 · 나라

- 한국 손님 위주 → .kr / .co.kr, 해외도 → .com
- 짧고 말로 불러도 헷갈리지 않게 (하이픈 · 숫자 피하기)
- 첫해 할인보다 갱신 가격 확인 · 상표 검색 · 방어 등록

도메인은 빌리는 것 : 연결하고 지키기

사자마자 할 일

- 내 명의 · 공용 이메일
- 자동 갱신 ON + 카드 만료일 확인
- 등록 업체 2 단계 인증 · 도메인 잠금
- DNS: A · CNAME(사이트), MX · TXT(메일)
- 바꾸기 전 DNS 설정 캡처

만료되면 (gTLD 기준 , 대략)

갱신 유예 ~45 일
원래 가격 갱신 가능한 경우 많음

복구 유예 ~30 일
사이트 · 메일 멈춤 , 비싼 복구비

삭제 대기 ~5 일
되살릴 수 없음

공개
누구나 등록 가능

업계 지식 (도메인 지식) 이란

그 분야의 업무 흐름과 단어 — 코딩 실력이 같아도 이걸 아는 사람이 실수 없는 서비스를 만든다

1
용어집
내 말로 단어 정리

2
흐름 그리기
돈 · 물건 · 정보의 이동

3
상태 그리기
주문이 거치는 모든 상태

4
예외 찾기
중간 취소 ? 부분 환불 ?

5
현장에 묻기
CS· 정산 담당의 고민

개발에선 DDD 공통 언어 (현업과 같은 단어를 코드에) · 영역 나누기 (같은 ' 주문 ' 도 판매팀 · 물류팀에서 뜻이 다름)

핵심 흐름 ①: 주문과 결제

쇼핑몰 주문 상태

결제 완료 → 상품 준비 → 출고 → 배송 중 → 배송 완료 → 구매 확정

예외 규칙 미리: 출고 전 취소 → 즉시 환불 · 출고 후 → 반품 전환 · 부분 반품 시 쿠폰·배송비

카드 결제

승인
결제 가능 확인 (돈은 아직)

매입
청구 확정

정산
수수료 빼고 D+N 일 입금

결제 핵심 설계: 멱등성 (두 번 눌러도 한 번만) · 매일 PG 내역과 주문 대사 (35 장)

핵심 흐름 ②: 분야별 꼭 알 단어

분야	꼭 알 흐름 · 단어
물류	입고 → 피킹 → 패킹 → 출고 → 배송 · 송장 · 합포장 · 3PL vs 풀필먼트
광고	광고주 DSP ↔ 익스체인지 (RTB 경매) ↔ SSP 퍼블리셔 · 어트리뷰션 · 퍼스트파티 데이터
게임	BM(F2P· 패스 · 가챠) · 라이브 옵스 · ARPPU · 리텐션 · 치팅
구독 ·SaaS	트라이얼 → 유료 전환 · 프로레이션 · 더닝 (결제 실패 재시도) · 멀티 테넌시
예약 ·O2O	슬롯 = 재고 (지나면 소멸) · 노쇼 · 예약금 · 동시 예약 충돌
금융	KYC · AML · 원장 (덮어쓰지 않기) · 대사 · 이상 거래 탐지

새 분야는 7 칸 표 (누가 · 돈 흐름 · 상태 · 예외 · 지표 · 규제 · 용어 20 개) 를 채우며 공부 (35 장)

출시 준비

서버 · 호스팅 고르기 · 꼭 해야 하는 보안 · 출시 전 Claude 에게 요청할 30 가지 — 36–38 장

서버 · 호스팅 : 사이트 종류로 고른다

사이트 종류	추천 출발점	내가 할 일
쇼핑몰	국내 쇼핑몰 빌더	거의 없음 (업체가 대부분 처리)
소개 · 랜딩 · 계산기	정적 호스팅	Git 에 올리면 자동 배포
블로그 · 정보	블로그 서비스 · 워드프레스 호스팅	플러그인 업데이트
회원제 ·AI 서비스 MVP	PaaS + 관리형 DB	코드만 , 서버 관리는 플랫폼
실시간 게임 · 큰 서비스	VPS · 대형 클라우드 (서울 리전)	보안 · 백업 · 비용 전부 직접

무료 요금제 함정 상업 사용 금지 · 잠자는 서버 · 한도 초과 정지 · 유료는 요금 폭탄 → 예산 알림

개인정보 해외 서버에 회원 정보 → 처리방침에 국외 이전 고지가 필요할 수 있음

꼭 해야 하는 보안

OWASP Top 10 (2025) 상위

1 **접근 권한 실패**
남의 주문이 주소만 바꿔 보임

2 **보안 설정 오류**
기본 비번 · 디버그 모드

3 **공급망 실패 (신규)**
오염 · 오래된 라이브러리

10 **예외 처리 실패 (신규)**
오류 화면에 내부 정보

누구나

- 모든 관리자 계정 2 단계 인증
- 공유 계정 금지 · 필요한 권한만
- HTTPS · 업데이트 · 백업 · 도메인 잠금

직접 개발이면 추가로

- 매 요청 주인 확인 · 금액은 서버에서 계산
- 해시 · 자리표시자 · 보안 헤더
- 비밀 키는 환경 변수 · 로그와 알림

개인정보 접속기록은 원칙 1 년 이상 (조건에 따라 2 년) 보관 · 유출 의심 시 확산 차단 → 증거 보존 → 신고 (37 장)

출시 전 Claude 에게 요청할 30 가지

첫인상 · 전환

- 첫 화면 CTA 1 개
- 모바일 고정 버튼
- 신뢰 요소 · FAQ
- 문의 답변 시간 표시

검색 노출

- 페이지마다 다른 제목 · 설명
- h1 · alt · 내부 링크
- robots.txt · 사이트맵
- 구조화된 데이터 · 404

공유 · 측정

- OG 태그 썸네일
- 파비콘 · 공유 버튼
- GA4 핵심 이벤트 · UTM
- 서치 콘솔 · 서치어드바이저

법 · 품질

- 처리방침 · 사업자 푸터
- 동의 분리
- 코어 웹 바이탈 · 접근성
- 보안 · 스팸 방지 · 모니터링

38 장 요청문을 복사해 보내고 , PageSpeed · 리치 결과 테스트 · 서치 콘솔 · 카카오 디버거로 확인

출시 직전 자주 하는 실수 4 가지

1	**robots.txt 로 숨기기**	숨기기 도구가 아님 → noindex 또는 비밀번호 . 운영 사이트 전체 Disallow 실수 확인
2	**가짜 404**	화면만 404, 상태 코드는 200 (소프트 404) → 실제 404 코드로
3	**카톡 썸네일이 안 바뀜**	카카오 캐시 → 공유 디버거 초기화 , 이미지 주소에 ?v=2
4	**화면과 다른 구조화된 데이터**	가짜 별점 · 없는 정보 표시는 스팸 정책 위반

코어 웹 바이탈 좋음 기준 : LCP ≤ 2.5 초 · INP ≤ 200ms · CLS ≤ 0.1

결제 · 게임 서버 · 어뷰징

결제 연동과 정산 · 롤 · 배그 같은 멀티플레이 서버 · 어뷰징 · 핵 대응 — 39–41 장

결제 연동 : 서버에서 검증하고 승인한다

주문 저장 → 결제창 → 성공 주소 → ★ 금액 검증 → ★ 서버 승인 → 결과 저장

금액 검증
브라우저 값은 조작 가능 → DB 금액과 같을 때만 승인

비밀 키
승인은 서버에서 , 시크릿 키는 환경 변수에만

웹훅
출처 확인 · 같은 알림 한 번만 · 빨리 200 응답

예외
두 번 클릭 · DB 저장 실패 시 자동 취소 · 부분 취소

PG 계약은 업종 심사가 먼저 · 개발은 테스트 키로 먼저 (39 장)

대사와 정산 : 돈을 매일 맞춰 본다

매일 대사

- PG 거래 내역 vs 우리 DB 를 주문번호로 짝맞추기
- PG 엔 있고 DB 엔 없음 = 돈 받고 주문 누락 (가장 위험)
- DB 엔 있고 PG 엔 없음 = 돈 안 들어온 주문
- 정산일엔 매출 - 취소 - 수수료 확인

플랫폼이라면

- 판매자별 정산 원장 (덮어쓰지 않고 추가만)
- PG 지급대행으로 판매자에게 지급
- 약속한 정산일은 반드시

티메프 사태 이후 정부 확정안 (2024.10)
대형 중개 플랫폼 : 구매 확정 후 20 일 내 정산 ,
판매대금 50% 이상 별도 관리 (시행일은 확인 필요)

멀티플레이 게임 뒤의 서버들

백엔드 서비스

로그인 · 친구 · 채팅 · 상점 · 전적 · 매치메이킹

일반 웹처럼 , 조금 늦어도 OK

전용 게임 서버

한 판의 실제 게임 진행 · 서버가 모든 판정

초당 수십 ~128 번 계산 · UDP

오케스트레이션

필요한 만큼 게임 서버 켜고 끄고 배정

Agones · GameLift 등

틱 레이트는 비용 발로란트 128 틱 = 7.8ms 마다 계산 · 틱을 2 배로 = 서버 비용도 약 2 배

지연을 숨기는 4 가지 기술

1 **클라이언트 예측**
내 입력을 서버 답 전에 화면에 바로 반영

2 **서버 보정**
서버 결과와 다르면 맞추고 남은 입력 다시 적용

3 **엔티티 보간**
다른 플레이어는 약간 과거 위치를 부드럽게

4 **지연 보상**
쏜 순간으로 시간을 되감아 명중 판정

기본 원칙 서버 권위 — 클라이언트는 입력만 보내고 판정은 서버가 · 격투 게임은 롤백 넷코드 , MOBA 는 결정론적 시뮬레이션

어뷰징 · 핵 : 4 단계로 대응

1. 설계로 막기 | **2. 입구에서 막기** | **3. 운영 중 찾기** | **4. 제재 · 개선**

서비스

- 혜택은 첫 구매 확정 후 · 1 인 (본인인증) 기준
- 봇 차단 · 속도 제한 · 유출 비번 거절
- 계정 탈취엔 2 단계 인증이 최고 (OWASP)
- 같은 기기 · 결제수단 · 주소 묶음 탐지

게임

- 서버 권위 · 보이는 정보만 전송
- 안티치트 (예 : Riot 뱅가드 , 부팅 시 시작)
- 비정상 명중률 · 재화 증가 탐지 · 신고 · 리플레이
- 핵 제작 · 유통 , 대리 게임 업은 법적 처벌

목표는 완벽 차단이 아니라 " 악용 비용 > 얻는 이익 " · 억울한 제재를 위한 이의 제기 창구 (41 장)

창업가의 기본기와 실전

검증 · 가격 · 돈 · 지원금 · 계획서 · 권리 · UX · AI 개발 · 테스트 · 단골 · 해외 · 외주 · 시간 관리 · 실습 — 42–56 장

만들기 전에 확인하기

1. 문제 | 2. 손님 | 3. 해결책 | **4. 지불** | 5. 경로

인터뷰는 과거 행동을 묻기

- ✕ " 이런 앱 있으면 쓰실래요 ?"
- ○ " 지난번엔 어떻게 해결하셨어요 ?"
- ○ " 돈이나 시간을 써 본 적 있으세요 ?"
- 칭찬은 검증이 아니다 , 행동이 검증

만들기 전에 팔아 보기

- 랜딩 페이지 + 이메일 수집
- 사전 판매 — 가장 강한 신호
- 사람이 직접 하는 수작업 서비스
- 출시 후 : " 매우 실망 " 40% 테스트

가격과 돈 관리

가격 (43 장)

- 원가 (바닥) 와 손님이 얻는 가치 (천장) 사이
- 너무 싸게 시작하지 않기
- 4 문항 가격 설문 → 사전 판매로 확인
- 3 단 요금제 , 가격 인상은 새 손님부터
- 해지는 쉽게 — 다크 패턴 금지

돈 관리 (44 장)

- 사업 통장 분리 · 증빙 보관
- 손익과 현금 흐름은 다르다
- 세금 통장에 미리 떼어 두기
- 법인세율 2026 년부터 1%p 인상 (10·20·22·25%)
- 법인 전환은 세무사와 비교

지원금 · 계획서 · 권리

지원금 · 투자 (45 장)

- 내 돈 → 매출 → 지원금 → 투자
- 예비창업패키지는 사업자등록 전
- 지원금은 증빙 · 정산 필수
- 투자는 지분을 파는 것

사업계획서 (46 장)

- 문제 · 해결 · 돈 · 팀 4 가지
- 형용사보다 숫자와 증거
- 발표 자료 10~15 장, 장당 메시지 하나
- AI 초안, 사실은 내가

권리 (47 장)

- 상표는 출원해야 생김 (먼저 낸 사람)
- 이미지 · 폰트 라이선스 확인
- 프롬프트만 넣은 AI 결과물은 권리 인정 어려움
- SaaS 는 AGPL 주의

만들기 : 화면 · AI 개발 · 테스트

UX· 문구 (48 장)

- 주인공 버튼 하나, 익숙한 배치
- 제목 : 누구 · 무엇 · 얼마나 쉽게
- 버튼은 동사로
- 5 명 사용성 테스트 반복

AI 로 개발 (49 장)

- 탐색 → 계획 → 구현 → 커밋
- CLAUDE.md 에 프로젝트 규칙
- 작게 나눠 단계마다 커밋
- 설명 못 하는 코드는 쓰지 않기

테스트 (50 장)

- 빈칸 · 두 번 클릭 · 뒤로 가기
- 남의 주문 번호 넣어 보기
- 기기별 시나리오 표 · 베타
- 자동 테스트는 돈 계산부터

키우기 : 단골 · 해외 · 외주 · 지치지 않기

1	단골 · 데이터 (51 장)	재구매가 있어야 광고비가 남는다 · RFM · 코호트 표
2	해외 진출 (52 장)	플랫폼 · 판매 대행부터 · 손님 나라 기준 세금 · GDPR
3	외주 · 팀 (53 장)	요구사항 문서 · 계약서에 범위 · 수정 · 권리 귀속
4	시간 · 번아웃 (54 장)	매일 3 가지 · 2 시간 집중 · 반복 일은 자동화 · 쉬는 시간도 일정에

직접 한 바퀴 : 실습 프로젝트 (55 장)

0 주	1 주	2 주	3 주	4 주	5~8 주
검증	설계	만들기	출시 준비	출시	운영 · 개선

주제	난이도	배우는 것
A. 계산기 · 도구 사이트 (추천)	★	정적 사이트 · SEO · 출시 체크리스트 · 광고
B. 디지털 상품 판매	★★	결제 연동 · 상세 페이지 · 정산
C. 오목 1:1 대전	★★★	웹소켓 · 서버 판정 · 어뷰징 대응

끝나면 회고 — 기획부터 운영까지 한 바퀴 돈 경험이 가장 큰 공부

바이브코딩으로 돈을 번 실제 사례 (57 장)

누가	무엇을 · 기간	결과 (본인 · 홍보 발표)	돈 버는 방식
피터 레벨스	비행 게임 · 약 3 시간	17 일 만에 월 87,000 달러 속도	게임 속 광고 · 유료 비행기
마크 루	매출 인증 사이트 · 약 하루	출시 48 시간 방문 35,000 명	광고 자리 월 299 달러 ~
Base44	AI 앱 빌더 · 6 개월	윅스가 8,000 만 달러에 인수	구독 → 매각
Plinq	안전 확인 서비스 · 45 일	연 매출 속도 약 45 만 달러	유료 조회
불혹코딩 (한국)	소규모 외주 · 8 개월	70 건 + 약 2,400 만 원	건당 외주비

숫자는 대부분 본인 SNS· 도구 회사 발표 — 감사받은 숫자가 아니고, 뒤에는 수많은 실패가 있다

사례에서 배울 것 · 조심할 것

진짜 성공 요인

- 이미 있던 관객 (팔로워) — 초보자는 지금부터 쌓기
- 손님을 잘 아는 분야에서 시작
- 빠르게 출시하고 처음부터 돈 받기
- 작게 여러 번 시도 (70 개 중 4 개)
- 초보자 첫 경로 : 작은 외주 → 도구 사이트

실패 사례에서 배우기

- 자랑 이틀 만에 공격 → 일주일 만에 종료
- API 키를 화면 코드에 → 서버에만
- 결제 확인은 반드시 서버에서
- AI 빌더 앱 10 곳 중 1 곳 데이터 노출 → RLS 켜기
- 홍보 전에 사용량 한도 · 알림

설계와 모듈화 (58 장)

기능별 폴더 + 세 층

```
src/
├ orders/   입구 → 규칙 → 저장
├ products/
├ users/
├ payments/ ← 결제 회사 감싸기
└ shared/
```

- 응집도는 높게, 결합도는 낮게
- 의존은 입구 → 규칙 → 저장 한 방향

AI 로 만들 때

- CLAUDE.md 에 구조 규칙 적기
- 코드 전에 구조를 표로 제안 → 승인
- 외부 API·비밀 키는 한 모듈·환경 변수에
- 정리는 한 번에 한 기능 + 테스트 + 커밋
- 결정은 ADR 로 남기기

데이터베이스 설계 (59 장)

1. 명사
2. 관계
3. 칸
4. 규칙
5. 조회

실수	이렇게
돈을 실수형으로 (0.1+0.2 ≠ 0.3)	원 단위 정수 · 소수 통화는 numeric
주문에 당시 가격 저장 안 함	주문 항목에 unit_price
주문·결제를 진짜 삭제	status 로 취소 표시
DB 를 손으로 수정	마이그레이션 파일 + 백업
수파베이스 RLS 꺼짐	모든 표에 RLS + 본인만 정책

API 설계 (60 장)

주소 · 결과

- 주소는 명사, 행동은 메서드
- /api/v1/orders/42
- 2xx 성공 · 4xx 요청 문제 · 5xx 서버 문제
- 에러는 RFC 9457 한 모양

중복 · 목록

- 주문 · 결제는 Idempotency-Key
- 같은 키 → 처음 결과 그대로
- 목록은 페이지네이션
- 피드 · 주문 내역은 커서 방식

안전

- 모든 요청에서 서버가 본인 확인
- 금액은 서버가 DB 가격으로
- 주소에 토큰 넣지 않기
- 사용량 제한 → 429

59·60 장의 예제 코드는 문서 그대로 실행해 결과를 확인했어요

유료 광고 심화 (61장)

광고 전에 · 합격선

- 상세 페이지 · 전환 추적 · 리뷰 먼저
- 손익분기 ROAS = 1 ÷ 마진율
- 마진 40% → 250% 미만이면 손해
- 처음엔 검색·쇼핑 광고 (찾는 사람)
- 구글은 검색 캠페인부터, PMax는 나중에

소재 · 측정

- 훅 → 본문 → 증거 → 행동 유도
- 한 번에 하나만: 훅 3~5개 비교
- 빈도↑ 클릭률↓ → 새 소재
- 픽셀 + 전환 API (중복 제거)
- 진짜 기준은 내 실제 주문·통장

브랜딩 · 출시 홍보 · 보도 · 인플루언서 (62 장)

포지셔닝 · 브랜드

- 대안 → 특징 → 가치 → 손님 → 분류
- 경쟁사보다 "대안" 먼저
- 같은 말투 · 색 · 약속을 오래
- 브랜드가 가격 경쟁을 줄인다

출시 · 보도자료

- 4~6 주 전부터 기다리는 사람 모으기
- 내 손님 있는 커뮤니티에 대화하듯
- 보도자료는 주제 하나
- 첫 문단에 핵심 , 숫자는 사실만

인플루언서

- 팔로워 수보다 손님층 일치
- 계약서에 표시 위치 · 문구
- 표시는 제목 · 첫 부분 (2025.12)
- "체험단" 같은 애매한 말 금지

콘텐츠 · 검색 노출 심화 (63 장)

1	키워드	긴 키워드 (롱테일) + 검색 의도 (알기 · 비교 · 사기 · 찾아가기) · 지금 1 페이지 직접 검색
2	글 구조	결론 먼저 · 질문 순서 소제목 · 직접 해 본 경험 · 숫자 · 표 · FAQ · 내부 링크
3	AI 검색	구글 공식 : 특별한 설정 불필요 · 요약에 없는 경험 · 도구 · 상품 제공 · 대량 생성 금지
4	운영	허브와 세부 글 묶기 · 매주 서치 콘솔 · 새 글보다 옛 글 고치기

이메일 · 카카오톡 자동 마케팅 (64 장)

흐름	시작 조건	성격
환영	가입 · 구독	내용에 따라
장바구니 이탈	담고 1~24 시간 결제 없음	광고성
구매 후 안내	결제 완료	정보성 (알림톡)
후기 요청	배송 3~7 일 뒤	내용에 따라
재구매 알림	다 쓸 때쯤	광고성
다시 돌아오기	60~90 일 활동 없음	광고성

친구톡은 2025 년 말 종료 → 광고성은 브랜드 메시지 · 동의자만 · 사면 바로 흐름에서 빼기 · 하루 1 통

기능 구현 실전 (65~69 장)

1	로그인 · 권한 (65)	인증은 맡기기 · 소셜 로그인 · 느린 해시 + 솔트 · 서버가 본인 데이터 확인
2	자주 쓰는 기능 (66)	업로드는 내용으로 형식 확인 · 한국어 검색은 조사 주의 · 예약 작업은 두 번 돌아도 안전하게
3	AI 기능 (67)	서버에서만 호출 · 토큰 비용 · 사용 한도 · 프롬프트 인젝션 : 돈 · 권한은 AI 에 맡기지 않기
4	속도 · 오류 · 비용 (68)	LCP 2.5 초 ·INP 0.2 초 ·CLS 0.1 · 오류 추적 + 요청 번호 · 예산 알림 · 사용량 상한
5	자동화 · 데이터 (69)	Zapier·Make·n8n · 공공데이터 먼저 · 크롤링은 형사 무죄여도 민사 배상 가능

사람과 돈 (70~71 장)

알바 · 직원 (70 장)

- 근로계약서 : 일 시작 전 , 작성 + 교부
- 2026 최저시급 10,320 원
- 주 15 시간 이상 → 주휴수당
- 주 40 시간 최저 월급 2,156,880 원
- 4 대보험 사장님 몫 +10% 이상 , 퇴직금 별도

세금 · 보험 · 신고 (71 장)

- 3 만 원 넘으면 적격증빙 (없으면 2%)
- 증빙 5 년 보관 , 사업용 카드 분리
- 노란우산 : 4 천만 원 이하 최대 600 만 원 공제
- 새 기능마다 신고 대상인지 확인
- 5 만 원 넘는 경품 → 22% 원천징수

물건 · 성장 · 공부 (72~74 장)

실물 상품 (72)

- 사진 : 대표 · 사용 · 크기 비교
- 재주문 = 하루 판매 × 입고일 + 안전 재고
- 택배는 반품 단가까지 비교
- 반품 사유 집계 → 페이지 개선

성장 운영 (73)

- 의견은 한 곳에 원문 그대로
- 지금 · 다음 · 나중 로드맵
- 추천 보상은 첫 구매 후 · 상한
- B2B: 짧은 콜드메일 · 문제 중심 데모

공부 루틴 (74)

- 만들면서 · 떠올려 보며 배우기
- 영어 문서 : 빠른 시작→ 가이드
- 도구 공지 · 법 · 보안은 꼭 따라가기
- 이 자료도 분기마다 재확인

출시 관문 — 등록 · 심사 · 서명 (75~76 장)

관문	언제	미리 안 하면
코드 서명 (윈도우 · 맥 공증)	PC 설치 프로그램	"PC 보호" 경고 · 백신 오탐
구글 플레이 12 명 ·14 일 테스트	개인 계정 첫 앱	출시 버튼이 안 열림
앱 계정 삭제 · 접근권한 고지	회원가입 · 권한 쓰는 앱	심사 거절 · 법 위반
구글 앱 검증 · 카카오 비즈 앱	로그인으로 정보 받을 때	경고 ·100 명 제한 · 정보 못 받음
Gmail 대량 발송 · 문자 발신번호	메일 · 문자 발송	스팸함 · 발송 차단
크롬 웹스토어 · 스팀	확장 프로그램 · PC 게임	등록비 · 심사 · 약 30 일 대기

출시 6~8 주 전에 관문 표를 보고 신청 날짜를 거꾸로 계산하기

인증 · 소비자 규칙 · 개발 도구 (77~79 장)

정부 · 인증 (77)

- 실물 : KC 인증 + 전파 인증
- 선택 : 저작권 등록 · 특허 · 벤처
- 특허는 공개 전에 고민
- 개인정보 보호책임자는 처음부터

구독 · 디지털 (78)

- 다크패턴 6 유형 법으로 금지
- 해지는 가입만큼 쉽게
- 유료 전환 · 인상 전 고지 · 동의
- 환불 제한 = 표시 + 맛보기

개발 도구 (79)

- 정규식은 예시 입력으로 테스트
- 도커 : 키는 환경 변수 , root 금지
- 잠금 파일 + 보안 알림
- 가짜 패키지 이름 주의

실습 사례 : 제품 " 한 바퀴 " (80 장)

0 준비 | 1 검증 | 2 설계 | 3 만들기 | 4 출시 준비 | 5 출시 | 6 운영 | 7 키우기

무엇을

- 교재를 외우는 대신 만들면서 안내받는 웹 서비스
- 53 개 스텝 (최종 시안 그리기는 선택)
- AI 코치가 내 단계를 기억하고 다음 할 일 안내
- 첫 사용자는 나 , 첫 프로젝트는 이 제품 자체

어떻게 (확정)

- Rust(Axum) + 서버 렌더링 + Supabase
- 도커 호스팅 · 1 주차부터 테스트 ·CI
- 1 주 진행표 → 2 주 로그인 · 배포 → 3 주 AI 코치
- 4 주 ~ 이 앱으로 이 앱의 출시 + 판매 검증

최적화와 안정화 (81 장)

안정화 — 먼저

- 출시 후 안정화 기간 : 기능 동결 + 끝내는 기준
- SLO 99.9% = 한 달 약 43 분 (에러 예산)
- 예산 다 쓰면 기능보다 안정화
- 타임아웃 · 재시도 (백오프 + 지터) · 차단기
- 카나리 배포 · 기능 스위치 · 롤백 연습

최적화 — 재고 나서

- 재기 → 가장 느린 곳 하나 → 고치기 → 다시 재기
- 인덱스 하나로 수백 배 (실측 예)
- N+1: 쿼리 101 번 → 1 번
- 큰 이미지 · 캐시 · 백그라운드 작업
- 전환율 최적화가 매출엔 더 클 때 많음

AI 코드 보안 점검 (82 장)

① 자동 도구 | ② AI 리뷰 | ③ 실제 공격 | ④ 테스트 · 승인

하는 일	오픈소스 · 도구 (무료 중심)
코드 패턴	Semgrep CE · clippy/Bandit/gosec · (CodeQL 은 비공개 상업용 유료)
비밀 키	Gitleaks (MIT) · TruffleHog (AGPL)
라이브러리	cargo/npm/pip audit · Trivy · OSV-Scanner
실제 공격	OWASP ZAP (스테이징)
AI 코드 필터 · 리뷰	CodeShield (메타) · Claude /security-review · 보안 리뷰 액션
허깅페이스	Foundation-Sec-8B (보안 특화 , 코드 탐지 전용 아님 · Llama 라이선스 확인)

엄격한 평가에서 AI 단독 탐지는 무작위 수준까지 — 발견 → 수정 PR → 막는 테스트 → 사람 승인

서비스 보안 전체 지도 (83 장)

1	사람 · 계정	피싱에 강한 2 단계 인증 · 퇴사 시 즉시 회수 · 이메일 · 도메인 · 클라우드 · 깃허브 계정 최우선
2	도메인 · 서버	도메인 잠금 · 지운 서비스의 DNS 정리 · 패치 · 자산 목록 · 관리망 분리
3	클라우드 · DB	저장소 · DB 기본 비공개 · 최소 권한 · RLS · 보안 규칙 · 민감 정보 암호화
4	공급망 · 결제	새 버전 며칠 기다리기 · 외부 스크립트 최소화 · 카드 정보는 PG 결제창에서만
5	단말기 · 감시	개발자 PC 보호 · 대량 조회 · 이상 로그인 알림 · 분리된 백업 · 정직한 공지

실제 사고 19 건의 교훈 (84 장)

교훈	사례
2 단계 인증 (피싱에 강한 방식)	스노우플레이크 · 우버 · MGM · npm
패치 + 자산 목록	SKT · 롯데카드 · 예스 24 · LastPass
평문 비밀 금지 · 퇴사 시 재발급	SKT · 쿠팡 · KT
저장소 ·DB 비공개 + 최소 권한	Tea 앱 · 캐피털원 · 노출 DB
공급망은 내 책임	MOVEit · npm · polyfill.io
분리된 백업 + 복구 연습	예스 24 · LastPass
빨리 알아채기 + 정직한 공지	SKT(4 년) · 쿠팡 (5 개월) · GS 리테일 · KT

프록시 · 동적 딜레이 · 브라우저 자동화 (85 장)

프록시

- 필요한 건 리버스 프록시
- HTTPS· 캐시 ·DDoS· 봇 관리
- 주거용 프록시는 피하기
- (동의 없는 기기 · IPIDEA)

동적 딜레이

- 상대가 힘들면 내가 느려지기
- robots.txt · 정직한 신분
- 429 · Retry-After 존중
- 외부 API 호출에도 적용

브라우저 자동화

- 내 서비스 E2E 테스트
- 합성 모니터링
- 글자 · 역할로 요소 찾기
- 차단 우회는 하지 않기

인터넷이 동작하는 원리 (86 장)

1	**IP · NAT**	IP 는 사람이 아니라 주소 · CGNAT 로 여럿이 한 주소 → IP 만으로 막으면 정상 손님도 막힘 · IPv6 접속 50% 돌파
2	**HTTPS**	내용은 숨김, 목적지 사이트 이름은 보임 · 믿도록 설정된 인증서로 프록시가 가로채 검사하기도 함
3	**프록시**	CONNECT 터널 (허용 200 / 차단 403) · 리버스 프록시 뒤 서버는 믿는 프록시의 X-Forwarded-For 만 믿기
4	**HTTP · 쿠키 · 캐시**	요청 · 응답은 글자 · 쿠키는 HttpOnly·Secure·SameSite · ETag→304 로 다시 안 받기
5	**브라우저**	CORS 는 서버 보안 아님 · SPA 는 진짜 브라우저가 있어야 보임 → 공개 페이지는 서버 렌더링

사업용 연락처 — 도메인 메일과 전화번호 (87 장)

1	원칙	개인 휴대폰 · 개인 Gmail 은 공개 안 함 · 연락처는 내가 바꿀 수 있는 것으로 (도메인 메일 + 두 번째 번호)
2	받기	처음엔 전달 (Cloudflare 등) 로 help@ → 내 Gmail · 답장이 많아지면 업무용 메일함으로
3	보내기	Gmail ' 다른 주소로 보내기 ' 는 DMARC 정렬 함정 · 발송 서비스 SMTP 또는 메일함 · 자동 메일은 하위 도메인
4	확인	원본 보기에서 SPF·DKIM·DMARC PASS · SPF 하나 · 조회 10 개 이하 · DMARC none → quarantine → reject
5	전화	투넘버 (쉬움) · 070(앱 · 녹음) · 050(번호 숨김) · 대표번호 (손님 통화료 주의) · 하단에 신원 정보 + 공정위 링크

안전하게 , 자주 반복하기

기획 → 백업 → 연습용 사이트에서 수정 → 확인 → 배포 → 감시 → 숫자 보기 → 다시 기획

다음 할 일 : docs/55-capstone-project.md 로 직접 한 바퀴 만들어 보기